

may change on an operational day-to-day basis. Therefore, SBOMs should be produced consistently, and when vulnerabilities are identified remediations should also be made consistently if a patch is available.

The ‘eternal’ debate and Log4j

The disclosure of the critical vulnerability in Log4j has sparked discussions online about the ‘eternal’ debate of open source sustainability. This discussion covers a broad collection of issues including licensing, business models, ethics, diversity and inclusion.

With the disclosure of Log4j, debates have re-surfaced on the ethics of how open source is developed, paid for (or lack thereof) and maintained. It is the maintainers, like those at the Apache Foundation, who must find the time to fix critical bugs like Log4Shell so that those upstream can secure their solutions.

Often, the voluntary contributions of maintainers to open source projects stem from a hobby. Whilst working day jobs, they can struggle to find the time to fix critical bugs, all the while facing demands from users requesting free support. Consequently, maintainer burnout is a challenge.

The fallout of Log4Shell made us all realise that we are relying on open source projects. The Internet and computing giants who arguably are “the heaviest users of open source in the world – are collectively worth trillions of dollars.” However, this wealth is not shared with the open source projects at the start of the supply chain.

In its annual open source security and risk report, Synopsys found that the number of open source components per commercial application jumped from 84 in 2016 to 528 in 2021. Yet the money that open source maintainers receive for working on this software hasn’t grown much, if at all.

Donations are commonly used as a source of funds for open source projects. For example, GitHub has set



Figure 4: Apple's goto fail within single quotes vulnerability (Image Source: <https://www.zdnet.com>)

up its GitHub Sponsors platform which allows users to donate to the projects they depend on. However, this source of funding may only be sustainable for extremely popular projects.

Filippo Valsorda, a Google cryptographer and security lead of the Go programming language, notes that contributors only get small amounts of money through GitHub or Patreon, while their projects may be responsible for millions of dollars. He adds that a bug in these important systems can break the Internet, and it's unfair to depend on people who work on these projects in their spare time without any assured rewards.

However, others believe that funding is not the issue; the real issue behind the Log4j crisis was that organisations did not know what was in their software. This lack of knowledge caused delays in patches and fixes. Without the delays, hacker exploits and security breaches may have been prevented.

Curl creator and WolfSSL developer Daniel Stenberg says, “The Log4j case is not a showcase for bad open source software funding.

It is a showcase for naive and cheap users not doing their due diligence, code review, and testing before using components. Remember ‘goto fail’ (Figure 4). Silly bugs are shipped even with the greatest funding.”

This debate brings us back to the need for SBOMs. If organisations were producing SBOMs in December 2021, they would have known whether they needed to implement fixes for Log4Shell immediately.

As consumers, there is an expectation for our cars, planes and even mundane items such as food processors to have a detailed bill of materials, because if any parts fail a product recall is expected. Why are companies not doing this for their software?

In a perfect world, all maintainers and projects would be adequately compensated. However, would this ensure that bugs like Log4j do not exist? We cannot be sure; but we do know companies are responsible for ensuring the code they ship to production is safe, secure and reliable. Therefore, the best we can do is be prepared and secure each link in the software supply chain. **END** 🐧

References

- [1] <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-44228>
- [2] <https://www.microsoft.com/security/blog/2021/12/11/guidance-for-preventing-detecting-and-hunting-for-cve-2021-44228-log4j-2-exploitation/>
- [3] <https://www.itpro.co.uk/security/cyber-security/361907/ftc-threatens-legal-action-companies-failing-to-patch-log4shell>

By: Holly Wyld

The author is a governance specialist at Source Code Control Limited.